

Anomali Senaryosu — OCPP Diagnostics Kanalı Üzerinden Sessiz Beaconing (Stealth Beaconing)

1. Başlık

OCPP Diagnostics Kanalı Üzerinden Sessiz Beaconing — Gizli Beacon'lar ile C2 Kanalı Kurma Girişimi (Savunma Odaklı Senaryo)

2. Kısa Özet (Abstract)

Bu senaryoda, kötü amaçlı bir yazılım veya zararlı bir güncelleme OCPP (Open Charge Point Protocol) diagnostic/monitoring mesajlarının içeriklerini kısmen manipüle ederek dışarıya küçük "beacon" paketleri gönderir. Bu beacon'lar geniş çapta dikkat çekmeyecek şekilde tasarlanır (ör. 1-2 byte metadata, rastgele fakat periyodik aralıklar) ve uzun vadede uzak bir C2 (command & control) kanalına dönüşebilir. Senaryo, prototip düzeyinde tespit ve müdahale stratejileri geliştirme amacına yöneliktir — saldırı adımlarını öğretmez, sadece savunma ve algılama yöntemlerini tanımlar.

3. Amaç & Kapsam

Amaç: OCPP diagnostics mesajlarının kötüye kullanımını savunma açısından analiz etmek; tespit yöntemleri ve mitigasyon önerileri sunmak.

Kapsam: Laboratuvar/izole ortamda simülasyon ve yalnızca savunma odaklı tespit planları. Canlı ağlarda izinsiz testler yapılmayacaktır. Proje, protokol şemaları, log analizi ve ağ izleme ile detection playbook'u sunar.

4. Senaryo (Nasıl İşler? — Savunma Dilinde)

1. Bir cihazda veya istasyon yazılımında (veya yönetim aracında) kötü amaçlı bir bileşen bulunur veya diagnostic mesajları üreten modül hatalı yapılandırılmıştır.
2. Bu bileşen, OCPP diagnostics mesajlarına gözle zor fark edilen küçük alanlar (ör. ek 1-4 byte metadata) ekler veya varolan alandaki bazı baytları periyodik olarak değiştirir.
3. Diagnostics mesajları normal günlük/operasyon logları içinde görünür; bu nedenle geleneksel log filtreleri tarafından gözden kaçma ihtimali yüksektir.
4. Az miktarda, düzenli aralıklarla gönderilen bu küçük değişiklikler, uzak bir dinleyiciye (C2) kısa sinyaller iletir — ilerleyen aşamalarda bu sinyaller üzerinden komut/koordinasyon yapılabilir.
5. Etkin bir saldırgan, bu kanalı uzun süre düşük yoğunlukla kullanarak tespit olasılığını minimize eder.

5. Gözlemlenebilir İşaretler / IOCs (Indicator of Compromise)

- Diagnostics mesajlarında beklenmeyen ek alanlar veya alışılmadık metadata (boyut değişiklikleri).

- Diagnostics mesaj formatında küçük, düzenli tekrar eden değişiklikler (ör. her N. mesajda 1–2 byte farklılık).
- Outbound bağlantılarda küçük, periyodik dış IP erişimleri (küçük veri miktarı).
- Log seviyesinde anormal artış veya farklı log şablonları (ör. normalde olmayan alanların dolması).
- Diagnostics mesajlarının hedeflenen zamanlarda (ör. gece yarısı, düşük trafik dönemleri) artışı.
- Şema veya protokol doğrulama hataları (schema conformance failures) ya da eksik/yanlış schema kullanımı.

6. Algılama Yaklaşımları (Savunma Odaklı)

6.1 Kolay / Hızlı Kontroller (Kural-Tabanlı):

- Schema Conformance: Tüm diagnostics mesajları için şema doğrulaması zorunlu kılın. Beklenmeyen alan/uzunluk hata üretsin.
- Boyut/Eşik Tespiti: Diagnostics payload boyutunda ani veya düzenli küçük artışlar için uyarı.
- Periyodiklik Algılama: Aynı istasyondan gelen diagnostics mesajlarında periyodik küçük değişiklikler (periodicity) tespit eden basit zaman-serisi kuralları.

6.2 Ağ Tabanlı Algılama:

- Outbound Trafik İzleme: Diagnostics kaynaklı dış bağlantıların IP/port bazlı izlenmesi; küçük ama düzenli dış isteklerin anomali olarak işaretlenmesi.
- DNS/TLS Fingerprint: Diagnostics kaynaklı outbound taleplerin DNS sorgu paternleri ve TLS sertifika fingerprint'lerinin incelenmesi.

6.3 Davranış-Tabanlı & ML Yaklaşımları:

- Sequence / Schema Anomaly Detection: Diagnostics mesajı içindeki alanların tipik düzenini öğrenen bir model (ör. küçük n-gram/byte-sequence modelleri).
- Periodicity Detection Model: Zaman bazlı küçük değişikliklerin tekrarını tespit eden model (Fourier/periodogram veya autocorrelation tabanlı).
- Ensemble: Kural tabanlı flag + ML skoru birleştirilerek yüksek güven skoruyla alarm üretme.

7. Mitigasyon & Önlemler (Uygulanabilir Adımlar)

7.1 Kısa Vadede (Hemen Yapılabilecekler):

- Schema Validation: Diagnostics mesajları için sıkı schema conformance doğrulaması etkinleştir. Beklenmeyen ek alanları reddet ya da alarm üret.
- Eşik ve Boyut İzleme: Diagnostics payload boyutlarını normal aralıkta tut; anormallikte alarm.
- Outbound Monitoring: Tüm cihazlardan çıkan küçük / düzenli trafik için IDS/IPS kurallarını ekle.
- Whitelist / Denylist: Diagnostics içeriğinde izin verilen alanlar/anahtarlar için beyaz liste uygulaması.

7.2 Orta / Uzun Vadede:

- Telemetry Integrity: Diagnostics/telemetry mesajlarına imzalama veya MAC ekleyerek gönderici doğrulaması sağla.
- Data Loss / Tamper Detection: Telemetry pipeline'nda checksum/sequence tracking ile içerik değişikliklerini tespit et.
- Logging & Retention: Diagnostics loglarını merkezi ve değiştirilemez bir yerde kısa süre sakla (ör. 30–90 gün) — forensics için yeterli tut.
- Code & Update Hygiene: Firmware/management yazılımlarında secure update ve code review süreçlerini güçlendir (SBOM, signed packages).

8. Test / Simülasyon Planı (Savunma-odaklı, izinli ortamda)

Not: Aşağıdaki adımlar yalnızca izole test ortamında ve yazılı izinle uygulanmalıdır.

1. Laboratuvar Kurulumu: Bir veya birkaç şarj istasyonu emülatörü (veya test cihazı), OCPP backend emülatörü ve ağ izleme/packet capture ortamı kur.
2. Benign Diagnostics Üretimi: Normal diagnostics akışını üret; payload boyutları ve alan yapısını kaydet.
3. Anomali Senaryosu (Saf Savunma Testi): Diagnostics payload'larına düşük yoğunlukta (ör. her 100 mesajda 1) küçük değişiklikler ekleyen kontrollü testler uygula — amaç detection tuning.
4. Detektör Tuning: Schema validation, payload-size alarm, periodicity detector'u çalıştır ve false positive'leri ayarla.
5. Raporlama: Tespit edilen IOCs, false positive sayıları, detection latency ve önerilen eşikler raporlanır.

9. Örnek IOCs — Hızlı Kontrol Listesi (SOC İçin)

- Diagnostics mesajları içeriğinde beklenmeyen metadata alanları.
- Tek bir istasyondan düzenli aralıklarla yapılan çok küçük outbound bağlantılar.
- Diagnostics payload boyutunda düzenli artış veya periyodik değişim.
- Schema conformance hataları veya beklenmeyen log seviyelerinde artış.
- Outbound IP'lerin bilinen C2/tor exit/şüpheli hosting sağlayıcılarına işaret etmesi.

10. Teslimatlar (Ne Sağlanacak?)

- Kısa rapor (PDF/Word): Senaryonun özeti, IOCs, önerilen kurallar.
- Detection playbook (1 sayfa): SOC için hızlı adımlar (alert → verify → isolate → collect).
- Test planı (kısa): Lab için adım adım simülasyon planı (izinli ortamda).
- Örnek kural seti: SIEM/IDS için birkaç örnek kural (schema mismatch, payload size threshold, periodicity alert).

11. Sonuç (Savunma Perspektifi)

OCPP diagnostics kanalı üzerinden gizli beacon gönderme taktiği, saldırganlar için cazip olabilir çünkü bu mesajlar operasyonel ve düşük öncelikli kabul edilir; bu yüzden sıkı schema doğrulaması yapılmıyor olabilir. Bu senaryoya karşı en etkili savunma, şema uyumluluğu, outbound trafik izleme, payload boyut kontrolü ve periodicity detection gibi katmanlı önlemlerle sağlanır. Uzun vadede telemetry integrity (imzalama, MAC) ve kurumsal yazılım güvenliği (signed updates, SBOM) en güçlü çözümlerdir.